



PARCOURS D'INTÉGRATION

Du PKI au ReBAC

Parcours de spécialisation — Terraform, workload identity et ReBAC, intégralement en open source

Bienvenue. Ce parcours de 10 semaines a été construit **spécifiquement à partir de votre profil**, et non sur un catalogue standard. Il s'appuie délibérément sur votre expertise PKI, OIDC et Keycloak comme point d'accroche : sur deux des trois sujets, vous ne partez pas de zéro mais d'une transposition. Tout se déroule sur un lab interne — aucun compte cloud, aucune licence, aucune ressource payante.

DURÉE	CHARGE INDICATIVE	COÛT	ENVIRONNEMENT
10 semaines	1 journée par semaine (≈ 70 h)	0 €	Lab local auto-hébergé

1. Ce sur quoi le parcours s'appuie

Le programme est conçu pour exploiter vos acquis comme raccourcis plutôt que pour reprendre des fondamentaux que vous maîtrisez déjà. Le temps a été réparti en conséquence : plus long là où le changement de paradigme est réel, volontairement court là où il ne s'agit que de transposer.

SUJET	POINT D'APPUI DANS VOTRE PARCOURS	NATURE DE L'APPRENTISSAGE	DURÉE
Terraform	Ansible, Jenkins, Git, culture IaC déjà installée	Changement d'outil. Le passage du procédural au déclaratif — le state, le graphe de dépendances, plan/apply.	3 sem.
Workload identity	OIDC en production, JWT, claims, PKI, fédération de confiance, HSM	Transposition. Le workload identity est de la fédération OIDC doublée d'une attestation cryptographique : le raisonnement vous est familier, l'outillage est nouveau.	3 sem.
ReBAC	RBAC Keycloak, realms, rôles, scopes, groupes	Nouveau paradigme. On ne demande plus « quel rôle a cet utilisateur » mais « existe-t-il un chemin dans le graphe entre ce sujet et cet objet ». C'est la phase la plus longue, et c'est volontaire.	4 sem.

Le socle de lab

Une seule pile technique, montée en semaine 1 et réutilisée jusqu'à la fin du parcours. Tout tourne en local — poste de travail ou VM interne. Aucun compte externe n'est nécessaire, et l'ensemble reste démontrable chez un client soucieux de souveraineté.

COMPOSANT	RÔLE DANS LE PARCOURS
k3s / kind	Le cluster Kubernetes support. Émetteur OIDC intégré, base de la phase 2.
Keycloak	Fournisseur d'identité et point de Token Exchange. Terrain connu — valorisé, pas contourné.
SPIRE	Attestation de charges de travail, SVID X.509. Le cœur de la phase 2.
OpenBao / Vault	Secrets dynamiques par authentification Kubernetes. Démontre le « zéro secret statique ».
MinIO	Service compatible S3, accepte les jetons d'identité fédérés. Cible du lab final de phase 2.
OpenFGA	Moteur ReBAC, en conteneur local. Le cœur de la phase 3.
OpenTofu / Terraform	L'outil qui décrit toute la pile ci-dessus, dès la phase 1.
Proxmox / OpenStack	Optionnel — l'infrastructure d'accueil si le lab est monté sur les moyens internes.

2. Séquencement

L'ordre suit des dépendances techniques réelles. Terraform d'abord, parce qu'il devient l'outil avec lequel se construit tout le lab des phases suivantes. Workload identity ensuite, parce qu'il s'appuie sur le cluster et sur Keycloak provisionnés en phase 1. ReBAC en dernier et sur la durée la plus longue.

PHASE	SEMAINES	CHARGE	SUJET
Phase 1	S1 – S3	≈ 21 h	Terraform
Phase 2	S4 – S6	≈ 21 h	Workload identity
Phase 3	S7 – S10	≈ 28 h	ReBAC

3. Le programme, phase par phase

PHASE 1 Semaines 1 à 3 · environ 21 h

Terraform

Le vrai obstacle n'est pas la syntaxe. Avec une pratique Ansible confirmée, HCL s'acquiert en deux jours. Le point qui demande un vrai effort, c'est le **state** : l'outil détient une représentation du réel et calcule un différentiel. C'est le passage du procédural au déclaratif — à attaquer frontalement dès la semaine 1.

PROGRESSION

- Semaine 1 — fondamentaux et state.** HCL, providers, resources, variables, outputs. init / plan / apply / destroy. Le state : fichier local, drift, terraform import, backend distant et verrouillage. Labs sur le provider **Docker**, sans aucun compte externe.

- Semaine 2 — structuration et Kubernetes.** Modules, `for_each` et `count`, data sources, workspaces, multi-environnements. Providers **Kubernetes** et **Helm** : c'est ici que se provisionnent le cluster et les composants du socle de lab. Comparaison explicite Ansible / Terraform : quand utiliser lequel, et pourquoi les deux coexistent.
- Semaine 3 — Terraform pour l'IAM.** Le cœur du poste. Un **realm Keycloak complet en Terraform** : clients OIDC, scopes, mappers, rôles. Puis les politiques **OpenBao/Vault** et, en option, les projets et rôles **Keystone** sur OpenStack.

RESSOURCES GRATUITES

HashiCorp — Tutorials Terraform

Officiel, gratuit

La meilleure ressource existante. Commencer par le parcours Get Started en version Docker (aucun compte cloud requis), puis Manage State et Modules.

<https://developer.hashicorp.com/terraform/tutorials>

OpenTofu — Documentation

Linux Foundation

Le fork open source de Terraform, sous licence MPL et gouvernance Linux Foundation. Même HCL, même écosystème de providers. À privilégier ici : cohérent avec un positionnement open source, et sans le risque de licence BSL.

<https://opentofu.org/docs/>

Terraform — Référence du langage

Doc officielle

Documentation de référence HCL, valable pour OpenTofu. À garder ouverte pendant les labs plutôt qu'à lire d'un bloc.

<https://developer.hashicorp.com/terraform/language>

Terraform Registry

Providers

Chercher les providers keycloak, kubernetes, helm, vault, openstack et docker. Les exemples du provider Keycloak sont le pont direct entre l'expertise IAM et l'IaC. Équivalent OpenTofu : search.opentofu.org.

<https://registry.terraform.io/>

Crossplane — Documentation

Open source

Une journée de survol en semaine 3. Objectif : savoir opposer le modèle Crossplane (contrôleurs Kubernetes réconciliant en continu) au modèle Terraform (plan/apply).

<https://docs.crossplane.io/>

LIVRABLE

Le socle de lab entier décrit en code : cluster, Keycloak avec un realm complet, OpenBao et MinIO, déployables par un seul apply. C'est à la fois le livrable de la phase et l'infrastructure des deux phases suivantes.

PHASE 2 Semaines 4 à 6 · environ 21 h

Workload identity

La phase la plus rapide, compte tenu du profil. Le workload identity supprime les secrets statiques en échangeant une identité attestée contre des credentials à durée courte. Émetteur, signature, validation d'audience, durée de vie, rotation : c'est du **PKI appliqué**. Le concept est déjà acquis ; ce qui s'apprend ici, c'est l'outillage — et sur infrastructure interne, cet outillage est plus explicite, pas moins : rien n'est masqué par une console managée.

PROGRESSION

- Semaine 4 — le mécanisme générique.** Le token de ServiceAccount projeté, l'émetteur OIDC du cluster (/well-known/openid-configuration), le JWKS, la validation d'audience et de durée de vie. Puis **Keycloak en fournisseur d'identité de charges de travail** et le **Token Exchange (RFC 8693)**.
- Semaine 5 — SPIFFE / SPIRE.** Le cœur de la phase. Identité de charge de travail portable et indépendante du fournisseur, fondée sur des **SVID X.509** : attestation de nœud, attestation de charge de travail, rotation automatique, mTLS entre services, fédération de trust domains. C'est le sujet où l'expertise PKI donne une longueur d'avance sur un profil cloud classique.
- Semaine 6 — le motif « zéro secret » de bout en bout.** Deux mises en œuvre : un pod obtient un secret dynamique d'**OpenBao/Vault** par authentification Kubernetes ; puis un pod obtient des credentials **MinIO** temporaires en échangeant son jeton d'identité fédéré. Clore par une **note de transposition** vers les noms commerciaux des hyperscalers.

RESSOURCES GRATUITES

SPIFFE / SPIRE — Documentation

Projet CNCF

Projet CNCF diplômé, entièrement open source. SVID X.509, attestation de nœud et de charge de travail, rotation automatique, fédération. La ressource centrale de la phase, et le pont le plus direct entre la PKI et le cloud-native.

<https://spiffe.io/docs/latest/spiffe-about/overview/>

Kubernetes — Service Accounts

Doc officielle

La projection de token, son audience, sa durée de vie et sa rotation. La brique de base de tout le mécanisme.

<https://kubernetes.io/docs/concepts/security/service-accounts/>

Kubernetes — Authentication

Doc officielle

La section sur l'émetteur OIDC du cluster et la découverte du JWKS : comment un tiers valide un token émis par le cluster, sans lui faire confiance a priori.

<https://kubernetes.io/docs/reference/access-authn-authz/authentication/>

RFC 8693 — OAuth 2.0 Token Exchange

Standard IETF

Une soirée de lecture. Standard cité dans le profil de poste, et directement praticable dans Keycloak.

<https://datatracker.ietf.org/doc/html/rfc8693>

Keycloak — Documentation

Open source

Sections Securing applications et Token exchange. Terrain connu, mais pour un usage nouveau : l'identité des charges de travail plutôt que celle des utilisateurs.

<https://www.keycloak.org/documentation>

OpenBao — Documentation

Linux Foundation

Le fork open source de Vault. Méthode d'authentification Kubernetes et secrets dynamiques : la démonstration la plus parlante du « zéro secret statique ». La documentation Vault équivalente reste applicable.

<https://openbao.org/docs/>

MinIO — Documentation

Open source

Section Security Token Service : MinIO accepte un jeton d'identité fédéré et rend des credentials temporaires. Le motif reproduit intégralement sur infrastructure interne.

<https://min.io/docs/>

LIVRABLE

Une démonstration exécutable : une application déployée sur le cluster interne accède à un bucket MinIO et à un secret OpenBao sans aucun secret stocké, identités portées par SPIRE, infrastructure entièrement décrite en Terraform. Accompagnée d'une note de transposition d'une page vers IRSA, Azure Workload Identity et GKE Workload Identity Federation.

PHASE 3 Semaines 7 à 10 · environ 28 h

ReBAC

La phase la plus longue, et le seul vrai changement de paradigme. On ne demande plus « quel rôle a cet utilisateur » mais « existe-t-il un chemin dans le graphe entre ce sujet et cet objet ». Le piège classique, quand on vient du RBAC Keycloak, est de modéliser en rôles ce qui doit l'être en relations. Le temps doit donc aller à la **modélisation**, pas à l'outillage : écrire un schéma OpenFGA correct est plus difficile que déployer OpenFGA.

PROGRESSION

- Semaine 7 — les fondations théoriques.** Lire le papier **Zanzibar** de Google, source de tout l'écosystème. Tuples de relation, modèle d'autorisation comme graphe, compromis cohérence / latence (les zookies). Poser par écrit la différence RBAC / ABAC / ReBAC avec des exemples issus de missions réelles.
- Semaine 8 — OpenFGA en pratique.** Le moteur le plus demandé (projet CNCF, issu d'Auth0). Langage de modélisation, types, relations, check, list-objects. Travailler dans le Playground — utilisable en local via Docker — avant d'écrire la moindre ligne d'intégration.
- Semaine 9 — modélisation avancée.** La semaine décisive. Hiérarchies (dossier vers document), héritage, groupes imbriqués, propriété, permissions publiques, exclusions. Modéliser un cas réel complet : multi-tenant avec délégation — précisément le type de sujet où le RBAC de Keycloak atteint ses limites.
- Semaine 10 — écosystème et architecture.** **SpiceDB** (Authzed) et **Ory Keto** en comparatif. Puis l'architecture d'intégration : où placer le point de décision (PDP) par rapport à l'API Gateway et à Keycloak, et comment l'authentification (Keycloak) et l'autorisation (ReBAC) se répartissent le travail.

RESSOURCES GRATUITES

Zanzibar — Google's Consistent, Global Authorization System

Papier fondateur

USENIX ATC '19, en accès libre (article et présentation). Tout l'écosystème ReBAC en descend. À lire en premier, avant tout outil.

<https://www.usenix.org/conference/atc19/presentation/pang>

OpenFGA — Documentation

Projet CNCF

Documentation officielle. La section Modeling (openfga.dev/docs/modeling) est remarquablement pédagogique et progressive : c'est le cœur de la phase. S'exécute intégralement en conteneur local.

<https://openfga.dev/docs>

OpenFGA Playground

Bac à sable

Écrire et tester un modèle d'autorisation dans le navigateur. Également disponible en local via Docker, ce qui permet de travailler sans rien envoyer à l'extérieur. À utiliser massivement en semaines 8 et 9.

<https://play.fga.dev/>

SpiceDB — Documentation Authzed

Open source

L'autre implémentation majeure, citée dans le profil de poste. Playground disponible sur play.authzed.com, et le serveur s'auto-héberge.

<https://authzed.com/docs>

Ory Keto — Documentation

Open source

L'implémentation Ory. Le poste mentionnant « Keycloak et/ou Ory », savoir positionner Keto face à OpenFGA est directement utile en entretien client.

<https://www.ory.sh/docs/keto>

LIVRABLE

Un modèle d'autorisation ReBAC complet pour une application multi-tenant, documenté, avec ses tests de check, et une note d'architecture positionnant le PDP face à Keycloak et à l'API Gateway.

4. Projet de synthèse

À faire courir en fond dès la semaine 3, et à finaliser en semaine 10. C'est ce qui transforme trois compétences apprises séparément en une référence démontrable devant un client — et ce qui restera de ce parcours.

Plateforme d'autorisation souveraine de démonstration

- **Infrastructure** décrite intégralement en Terraform / OpenTofu, déployée sur les moyens internes (Proxmox ou OpenStack).
- **Authentification** par Keycloak — le terrain de compétence historique, valorisé et non contourné.
- **Autorisation** déléguée à OpenFGA, avec un modèle relationnel documenté.
- **Identité des charges de travail** par SPIRE : SVID X.509, rotation automatique, aucun secret statique dans la plateforme.
- **Argument commercial** : une plateforme d'autorisation moderne qui ne dépend d'aucun hyperscaler — exactement le discours attendu sur les sujets de souveraineté et de sortie de dépendance.
- **Point différenciant** : la chaîne de confiance expliquée de bout en bout, de l'attestation de la charge de travail jusqu'à la décision d'autorisation. Peu de profils cloud savent la raconter ; un expert PKI, oui.

5. Jalons et suivi

Chaque phase se termine par une revue : démonstration du livrable, points ouverts, ajustement du rythme de la suivante.

JALON	LIVRABLE ATTENDU	ÉCHÉANCE
Fin de phase 1	Socle de lab entier déployable par un seul apply	Semaine 3
Mi-phase 2	Token Exchange (RFC 8693) mis en œuvre dans Keycloak	Semaine 4
Fin de phase 2	Démonstration « zéro secret » avec identités portées par SPIRE, et note de transposition vers les offres des hyperscalers	Semaine 6
Fin de phase 3	Modèle ReBAC multi-tenant + note d'architecture du PDP	Semaine 10
Clôture	Projet de synthèse présenté en interne	Semaine 10

FONCTIONNEMENT

- **Point hebdomadaire de 30 minutes** — avancement, blocages, réajustement de la charge selon le taux d'occupation en mission.
- **Revue de fin de phase** — démonstration du livrable et passage à la phase suivante.
- **En cas de débordement**, les phases suivantes sont décalées plutôt que tronquées : les dépendances techniques entre phases sont réelles.

6. Pour aller plus loin

Deux lectures complémentaires, hors programme mais directement utiles en clientèle. Quelques heures suffisent pour chacune.

NIST SP 800-207 — Zero Trust Architecture

Gratuit

La référence internationale sur le Zero Trust, en accès libre. Un après-midi de lecture donne un discours structuré, qui s'articule naturellement avec le projet de synthèse — lequel est, techniquement, une implémentation Zero Trust.

<https://csrc.nist.gov/publications/detail/sp/800-207/final>

ANSSI — Référentiel SecNumCloud

Gratuit

Référentiel publié en libre accès sur le site de l'ANSSI. La maîtrise déjà acquise d'eIDAS, NIS2 et ISO 27001 rend la transposition rapide, et SecNumCloud prolonge exactement le choix d'une plateforme sans hyperscaler.

<https://cyber.gouv.fr/>

Toutes les ressources listées sont gratuites à la date de rédaction : documentations officielles des éditeurs et projets open source. L'intégralité du parcours s'exécute sur infrastructure interne, sans compte cloud ni licence. Seule la certification Terraform Associate est payante et reste optionnelle — son financement peut être discuté au point hebdomadaire. La charge d'une journée par semaine est indicative et s'ajuste selon les impératifs de mission.